

TradeVault

Audit Architecture

CTO Staff Engineer Audit - Pre-Funding Round

Juillet 2026

Rapport confidentiel destine a l'equipe technique TradeVault

Ne pas diffuser en externe sans autorisation

Methodologie d'Audit

Cet audit a été réalisé par analyse statique de l'intégralité du code source de TradeVault (~271 fichiers, ~25 000 lignes de code). Chaque couche de l'architecture a été examinée individuellement ainsi que ses interactions avec les autres couches. Les critères d'évaluation suivent les principes SOLID, Clean Architecture, et les contraintes spécifiques de TradeVault (séparations des couches strictes, moteurs purs, event-driven, provider-agnostic).

Les problèmes sont classés par urgence : P0 (bloquant, sécurité, perte de données), P1 (dette significative, performance, scalabilité), P2 (mineur, cosmétique). Le score global sur 100 reflète la santé architecturale du projet.

1. Violation de la Separation des Couches

La regle cardinale de TradeVault est : 'src/tradevault/ (UI) importe src/modules/ - jamais l'inverse.' Cette regle est violee dans 8 fichiers critiques, creant un couplage bidirectionnel entre la couche UI et les modules metier. C'est le probleme architectural le plus grave du projet.

P0 Modules et Backend importent depuis l'UI (app/)

modules/notifications/engine.ts, modules/ai/memory.ts, modules/discipline/engine.ts, modules/discipline/types.ts, modules/automation/types.ts, modules/

Pourquoi : Des fichiers dans modules/ et backend/ importent depuis @/app/ (UI). Les types metier fondamentaux (Trade, TradingRule) et le

Impact : Le code serveur importe du code navigateur (Supabase browser client). SSR crash. Bundles server gonflés. Impossible d'extraire

Correction : Extraire Trade -> modules/trading/types.ts. Extraire TradingRule -> modules/discipline/types.ts. Extraire generateId -> modules/shared/utills.ts. Deplacer checkTradeAgainstRules dans modules/discipline/.

P0 Cross-boundary imports dans App.tsx

src/app/App.tsx:43-46

Pourquoi : App.tsx importe directement backend/ (reports.functions, push.functions) et modules/ (automation), creant un couplage fort entre

Impact : Tout changement dans backend/ ou modules/ peut casser App.tsx. Impossible de tester l'UI independamment.

Correction : Introduire un service interface (ex: ITradeService, IAIService) ou un hook custom qui encapsule l'appel backend.

P0 UseSubscription utilise chemin relatif au lieu d'alias

src/app/hooks/useSubscription.ts:2

Pourquoi : Import relatif '../integrations/supabase/client' au lieu de '@/' etabli partout ailleurs.

Impact : Si la structure de dossiers change, cet import casse silencieusement.

Correction : Uniformiser avec @/integrations/supabase/client.

2. Event Bus - Systeme Nerveux

Contrat vs Realite

L'Event Bus est presente comme le systeme nerveux de l'application, mais souffre de plusieurs tares : handlers non awaits, events declares jamais emis, events emis sans listeners, effets de bord au niveau module, et pas de mecanisme de persistance.

P0 Handlers jamais awaits - perte de donnees silencieuse

src/modules/events/bus.ts:36-39

Pourquoi : emit() itere les handlers de facon synchrone avec .catch() mais sans await. Si un handler async echoue ou si le process se term

Impact : Perte de donnees garantie en production. Impossible de savoir si un traitement de fond a reussi.

Correction : Rendre emit() async avec await Promise.all() ou implementer une queue memoire avec flush.

P0 Module-level side effects - listeners enregistres a l'import

src/modules/notifications/engine.ts:103-138, src/modules/automation/engine.ts:67-111

Pourquoi : events.on() et registerStep() executes au MODULE SCOPE. L'import du fichier enregistre des listeners globaux permanents. Re

Impact : Impossible de tree-shake. Accumulation de listeners dupliques en HMR. Le SSR importe ces modules et enregistre des listeners c

Correction : Deplacer dans init()/configure() explicite. Capturer les unsubscribes.

P1 12 events declares jamais emis - dead contract surface

src/modules/events/types.ts:26-48

Pourquoi : GoalUpdated, GoalCompleted, DailyBriefReady, WeeklyReviewReady, NewPatternDetected, DailyReset, AgentRunStarted, Ag

Impact : Interface API trompeuse. Les developpeurs implementent contre des events sans emetteur.

Correction : Soit implementer les emetteurs, soit supprimer les declarations.

P1 5 events emis sans aucun listener

automation/engine.ts (cross-ref avec events/types.ts)

Pourquoi : TradeCreated, TradeUpdated, TradeDeleted, TradeAnalyzed, NotificationCreated sont emis mais aucun listener ne les ecoute.

Impact : Architecture event-driven incomplete. Pas de notification sur ajout/analyse/suppression de trade.

Correction : Enregistrer au minimum un listener Toast pour TradeCreated/TradeDeleted.

3. Plateforme IA - Provider-Agnostic

La plateforme IA est le domaine le plus contraste du projet : une architecture en partie brillante (provider-agnostic, context builder, prompt builder) noyee dans ~40% de scaffolding type-only sans aucune implementation runtime. C'est un risque majeur de perception (vaporware) avant une leve de fonds.

Infrastructure morte ou inutilisee

P0 Infrastructure IA deployee mais non utilisee par le code de production

src/modules/ai/infra.ts, src/modules/ai/tools/, src/modules/ai/router/, src/modules/ai/agents/registry.ts

Pourquoi : Le barrel infra.ts est documente comme point d'entree mais importe par zero fichier de production. Les fonctions AI dans backend

Impact : 300+ lignes d'infrastructure sophistiquee avec zero couverture runtime. Le router AI, le tool calling, l'agent registry - tout est inerte.

Correction : Soit refactorer backend/ai.functions.ts pour utiliser modules/ai/, soit retirer l'infrastructure inutilisee. Ne pas laisser les deux en parallele.

P1 5 agents declares dans le catalogue - zero enregistres a runtime

src/modules/ai/agents/catalog.ts, registry.ts

Pourquoi : AGENT_CATALOG definit 5 blueprints (coach, performance-analyst, psychologist, risk-manager, pattern-finder) avec personae

Impact : listReadyAgents() retourne toujours []. Le Coach fonctionne en direct via runCoach() mais ne participe pas au systeme d'agents.

Correction : Enregistrer coach.agent.ts comme AgentDefinition. Pour les 4 autres, soit implementer des stubs, soit aligner le catalogue avec la realite.

P1 10 tools declares dans le catalogue - zero enregistres

src/modules/ai/agents/catalog.ts:22-62, src/modules/ai/tools/types.ts:55

Pourquoi : get_stats, get_trades, search_memory, get_rules, get_goals, compute_quant_stats, get_discipline_events, assess_trade_risk s

Impact : Le tool-calling loop runWithTools() echoue systematiquement: 'Unknown tool: {name}'.

Correction : Implementer et enregistrer chaque tool declare. Au minimum des stubs qui retournent 'not implemented'.

P1 RAG/MCP/Jobs/Telemetry - 100% contractuel, 0% runtime

src/modules/ai/rag/types.ts, src/modules/ai/mcp/types.ts, src/modules/ai/jobs/types.ts, src/modules/ai/telemetry.ts

Pourquoi : EmbeddingProvider, Retriever, McpClientAdapter, JobQueue, TelemetryRecorder sont tous definis comme types/interfaces. Au

Impact : Les fonctionnalites promises (semantic search, outils externes, jobs background, observabilite) sont impossibles a livrer sans reec

Correction : Marquer clairement en documentation comme 'planned Q3/Q4' ou reduire l'empreinte a un design doc.

Problemes d'execution

P0 Env vars IA lues au module scope - stale a l'execution

src/modules/ai-provider/openai.ts:17, anthropic.ts:12, gemini.ts:8

Pourquoi : const MODEL = process.env.OPENAI_MODEL || 'gpt-4o-mini' evalue a l'import, pas a la requete. isConfigured() lit process.env

Impact : Tests avec differents modeles casses. Changement d'env var require restart process. Incoherence entre les methodes.

Correction : Lecture lazy dans complete() et isConfigured() - helper functions.

P0 Gemini provider: detection erronee de credits epuises

src/modules/ai-provider/gemini.ts:51-52

Pourquoi : Le code verifie HTTP 402/403 pour 'credits exhausted'. L'API Gemini ne retourne jamais ces codes - elle retourne 429 (rate limit)

Impact : La logique de fallback ne se declenche jamais correctement pour Gemini. L'application croit gerer un cas qui n'existe pas.

Correction : Remplacer par la detection 429. Le catch-all couvre deja les autres erreurs.

P2 Pas de byte-size cap sur la serialisation des trades

src/modules/ai/context.ts:110-111

Pourquoi : JSON.stringify(ctx.trades, null, 1) serialise jusqu'a 500 trades avec 9+ champs chacun = ~500 KB potentiel.

Impact : Peut exploser la fenetre de contexte du modele (Gemini 1M tokens accepte, mais Claude 200K non).

Correction : Capper par byte-size (ex: slicer jusqu'a 12 KB) plutot que par count.

4. SSR, Server Functions et Backend

Crash SSR et Auth

P0 localStorage cote serveur - crash SSR garanti

src/modules/notifications/engine.ts:27

Pourquoi : localStorage.getItem('tv.lang') execute dans des handlers d'evenements. Si le module est importe cote serveur (inevitable), Refe

Impact : CRASH TOTAL en SSR. Application inaccessible jusqu'a ce que le process soit relance.

Correction : try/catch autour de tout acces localStorage, ou injecter la preference de langue via parametre de fonction.

P0 auth-middleware utilise getClaims() - API non standard

src/integrations/supabase/auth-middleware.ts:56

Pourquoi : supabase.auth.getClaims(token) n'existe pas dans l'API publique du SDK Supabase v2.107. La methode standard est supabase

Impact : TOUTES les server functions authentifiees cassent si la methode est retiree ou renommee dans une mise a jour du SDK.

Correction : Remplacer par supabase.auth.getUser(token) - API publique standard.

P0 No-op input validator sur push.functions

src/backend/push.functions.ts:17

Pourquoi : .inputValidator((input: SendInput) => input) est une fonction identite. Zero controle runtime.

Impact : Tout utilisateur authentifie peut injecter des donnees non controlees dans le pipeline de push Web.

Correction : Schema Zod avec z.string().max(100) etc.

Endpoints HTTP non proteges

P0 Zero rate limiting sur les endpoints HTTP bruts

src/server.ts:40-89

Pourquoi : Aucun rate limiting sur /api/billing/*, /api/crypto/*, /api/emails/*, /api/stripe/webhook.

Impact : Attaquant peut flood => couts Stripe/Resend illimites. Charges DB non controlees.

Correction : Rate limiter IP-based sur tous les endpoints non-AI, au meme titre que consume_ai_quota pour l'IA.

P0 Crypto webhook crash sur payload malforme

src/backend/crypto-pay.server.ts:90-98

Pourquoi : JSON.parse(payload).event sans try/catch.

Impact : 500 error, Coinbase retry, delai de souscription pour le client.

Correction : try/catch avec retour 400.

P1 Aucune validation Zod sur les endpoints billing et crypto

src/backend/billing.server.ts:135-187, src/backend/crypto-pay.server.ts:39-47

Pourquoi : Verifications ad-hoc (if plan !== 'pro_monthly') sans schema Zod. Promo code completement non valide.

Impact : Contrat d'API implicite et non testable. Risque d'injection bas niveau.

Correction : Schemas Zod pour chaque endpoint: z.enum(['pro_monthly', 'pro_yearly'], z.string().max(30).optional()).

Duplication de code backend

P1 json() helper duplique 3 fois, siteUrl() duplique 2 fois

src/backend/billing.server.ts, lifecycle-emails.server.ts, crypto-pay.server.ts

Pourquoi : Les fonctions json(body, status) et siteUrl(request) sont definies identiquement dans 3 et 2 fichiers respectivement.

Impact : Tout changement de format de reponse doit etre fait en 3 endroits. Risque de divergence.

Correction : Extraire dans src/shared/response.ts.

P1 TradeSummary Zod schema duplique 2 fois

src/backend/coach.functions.ts:14, src/backend/ai.functions.ts:19

Pourquoi : Le schema TradeSummary est defini identiquement dans les deux fichiers.

Impact : Les schemas divergent inevitablement avec le temps. Validation incoherente.

Correction : Extraire dans src/shared/schemas.ts.

P1 Cron endpoints acceptent toute methode HTTP

src/server.ts:46-65

Pourquoi : Les endpoints /api/cron/* acceptent GET, POST, etc. alors qu'ils devraient exiger POST.

Impact : Un crawler ou prefetch declencherait des emissions de rapports ou d'emails.

Correction : Ajouter request.method === 'POST'.

5. Couche React et UI

Performance et Re-renders

P1 N+1 upsert pendant l'import CSV

src/app/App.tsx:286-333

Pourquoi : Les trades sont sauvegardés séquentiellement dans une boucle for avec upsertTrade individuel. Pour 500+ trades, 500+ appels

Impact : Import CSV de 500 trades = 10+ secondes. UX dégrade. Cout API Supabase multiplie.

Correction : Batching avec upsert bulk Supabase (.upsert avec tableau).

P1 3 useEffect séquentiels pour des requêtes DB indépendantes

src/app/pages/Dashboard.tsx:95-118

Pourquoi : loadStartingBalance, loadTradingPlan, loadOnboarding - 3 appels DB séquentiels qui pourraient être parallèles.

Impact : Latence triplée sur le chargement du dashboard.

Correction : Promise.all() pour paralléliser.

P1 computeEdgeScore recalcule à chaque render

src/app/pages/Dashboard.tsx:209-213

Pourquoi : Edge score $O(n)$ + localStorage dans useMemo avec trades comme dépendance. Recalcule à chaque modification de trades.

Impact : Avec 1000+ trades, latence perceptible à chaque changement.

Correction : Memoization avec un hash stable ou worker.

P1 Trading rules chargées 2 fois - dual source of truth

src/app/App.tsx:158-171 + src/app/hooks/useTradingRules.ts

Pourquoi : App.tsx a rulesRef (mutable ref) ET useTradingRules a rules (state). Tous deux écoutent le même custom event tv-rules-update

Impact : Les deux sources peuvent diverger temporairement. Bugs intermittents.

Correction : Single source of truth: soit le hook, soit le contexte.

Anti-patterns React

P1 Fire-and-forget async IIFE sans .catch()

src/app/App.tsx:196-208

Pourquoi : void (async () => { ... AutomationEngine.tradeSaved(...) })() sans .catch(). Si la promesse reject, l'erreur est avalée.

Impact : Silent failure de l'analyse de trade. L'utilisateur croit que tout va bien, mais les métriques ne sont pas calculées.

Correction : Ajouter .catch() avec error reporting.

P1 setTrades shim opaque - patche React Query cache

src/app/App.tsx:75-81

Pourquoi : setTrades est une fonction qui modifie directement le cache React Query via queryClient.setQueryData. Le nom est trompeur (r

Impact : Un nouveau développeur utilisant setTrades(x) ne saura pas qu'il mute le cache React Query, pas l'état local.

Correction : Renommer en updateTradesCache() ou utiliser un mutation helper explicite.

P1 Module-level mutable state `_activeAccountId`

src/app/store/accounts.ts:18-24

Pourquoi : Variable globale `_activeAccountId` persistee au niveau module. Deux composants pendant le meme render auront la meme valeur.

Impact : Impossible de tester en parallele (cross-test contamination). Violation des principes React data-flow.

Correction : Remplacer par React Context + state.

P1 Window event bus (tv-rules-updated) contourne React

src/app/hooks/useTradingRules.ts, src/app/App.tsx

Pourquoi : Custom events sur window pour la communication cross-composant. Bypass le systeme de contexte React.

Impact : Escape hatches non documentes. Difficile a tracer. Pas de typage.

Correction : Remplacer par un contexte React dedie ou une store Zustand.

6. Design System et Styles

P1 700+ lignes de CSS landing page dans le bundle global

src/styles.css:925-1670

Pourquoi : Les styles landing (.landing-root, .glass-card, .ai-card, .hud-ring, etc.) sont dans styles.css charge sur toutes les routes, meme p

Impact : 300KB+ de CSS inutile sur chaque page app. Ralentit LCP et FCP.

Correction : Code-split via CSS module importe seulement par Landing.tsx.

P1 4 Google Fonts chargees, 3 inutiles au quotidien

src/routes/__root.tsx:99-101

Pourquoi : Inter (4 poids), Space Grotesk (3), Sora (4), Manrope (5) = 16 fichiers de font. L'app utilise principalement Manrope + Sora.

Impact : ~200KB+ de polices non utilisees telechargees sur chaque page.

Correction : Garder Manrope 400,500,600,700 et Sora 600,700,800. Supprimer Inter et Space Grotesk.

P0 user-select: none global empeche la selection de texte

src/styles.css:325-337

Pourquoi : body { -webkit-user-select: none; user-select: none; } bloque la selection de tout texte hors inputs.

Impact : Les utilisateurs (traders pros) ne peuvent pas copier des chiffres, des erreurs, des notes. UX degradante pour un outil professionn

Correction : Supprimer le global ou le scoper aux surfaces gesture-only (graphiques).

P2 !important sur les styles recharts tooltip

src/styles.css:650-653

Pourquoi : .recharts-tooltip-wrapper { outline: none !important; transition: ... !important; }.

Impact : Arme CSS. Impossible de surcharger le style sans !important aussi.

Correction : Selecteurs specifiques au lieu de !important.

7. Mobile et Accessibilite

P1 Zoom lock JS bloque les utilisateurs malvoyants

src/shared/lock-zoom.ts:9-50

Pourquoi : Le zoom lock annule pinch-zoom, double-tap zoom, et Ctrl+wheel. Bien qu'intentionnel pour 'native app feel', cela exclut les utilisateurs malvoyants.

Impact : Violation WCAG 2.1 Criterion 1.4.4 (Resize text). Risque legal dans certaines juridictions (ADA, RGAA).

Correction : Utiliser CSS touch-action: pan-x pan-y sans le JS event prevention. Ou rendre le zoom lock optionnel dans les preferences.

P1 Direction badges 'L', 'S', 'BE' non explicités pour lecteurs d'écran

src/app/pages/Journal.tsx:358-369

Pourquoi : Les badges 'L', 'S', 'BE' (Long, Short, Break-even) sont affichés en 11px bold sans aria-label.

Impact : Les lecteurs d'écran lisent 'L' comme la lettre et non 'Long'. Inaccessible.

Correction : Ajouter aria-label={t('direction.long')} etc.

P2 ConfirmContext modal sans aria-modal ni focus trapping

src/app/contexts/ConfirmContext.tsx:40-41

Pourquoi : Le modal overlay dismiss au click sans role='alertdialog' ni focus trapping.

Impact : Navigation au clavier piège. Les utilisateurs de lecteurs d'écran ne savent pas que c'est un dialogue.

Correction : Ajouter role='alertdialog', aria-modal='true', et focus trap.

P2 lang='en' hardcode dans le HTML SSR

src/routes/__root.tsx:116

Pourquoi : L'app supporte 11 langues mais le SSR déclare toujours <html lang='en'>.

Impact : Les lecteurs d'écran utilisent les mauvaises règles de prononciation. SEO pénalise pour les marchés non-anglophones.

Correction : Rendre dynamique selon le profil utilisateur ou l'en-tête Accept-Language.

8. Supabase et Base de Donnees

Problemes d'integrite

P0 trades.user_id sans FOREIGN KEY vers auth.users

supabase/migrations/20260605201359_*.sql:36

Pourquoi : user_id uuid NOT NULL default auth.uid() sans REFERENCES auth.users(id) ON DELETE CASCADE.

Impact : Pas de cascade de suppression. Si auth.users est supprime, les trades deviennent orphelins.

Correction : ALTER TABLE ADD CONSTRAINT FOREIGN KEY ON DELETE CASCADE.

P0 Migration duplquee - conflit SQL en environnement frais

supabase/migrations/20260607165855_92190bbb-*.sql

Pourquoi : CREATE TABLE public.profiles et CREATE TABLE public.trades sans IF NOT EXISTS, en double avec le fichier 20260605201359_*.sql

Impact : Un environnement Supabase frais ne peut pas appliquer les migrations en ordre.

Correction : Supprimer le fichier duplique.

P0 Storage bucket trade-screenshots jamais cree en SQL

Toutes les migrations storage policies

Pourquoi : Les RLS policies sur storage.objects existent pour le bucket, mais aucune migration ne fait INSERT INTO storage.buckets.

Impact : Cree manuellement en prod mais absent en environnement frais. Les uploads de screenshots echouent sans erreur claire.

Correction : Migration additive: INSERT INTO storage.buckets ... ON CONFLICT DO NOTHING.

P0 delete-account Edge Function oublie 13 tables

supabase/functions/delete-account/index.ts:57-60

Pourquoi : Supprime uniquement de trades, missed_opportunities, push_subscriptions, profiles. Manque: accounts, subscriptions, email_logins

Impact : Donnees orphelines massives apres suppression de compte. Non-conformite RGPD.

Correction : Ajouter chaque table manquante avec .delete().eq('user_id', uid).

P1 Pas de CHECK constraint sur trades.direction

Migrations trades table

Pourquoi : direction text NOT NULL DEFAULT 'long' sans CHECK. Le type TS TradeDirection = 'long' | 'short' | 'be' n'est pas enforce en DB.

Impact : Bugs applicatifs ou ecritures DB directes peuvent inserer des valeurs invalides qui font crasher le render.

Correction : ALTER TABLE ADD CONSTRAINT trades_direction_check CHECK (direction IN ('long','short','be')).

P1 updated_at triggers absents sur goals et habits

supabase/migrations/20260717110000_goals_rules.sql, 20260717150000_trading_plan_goal_plans.sql, 20260718120000_engines_foundation.sql

Pourquoi : Ces tables ont une colonne updated_at mais aucun trigger pour la mettre a jour automatiquement.

Impact : updated_at reste null ou stale. Cache invalidation et changelogs bases sur updated_at sont casses.

Correction : Ajouter les triggers. habits n'a meme pas la colonne - l'ajouter aussi.

P1 ai_os_foundation.sql marque 'NOT YET APPLIED' mais dans le dossier de migrations

supabase/migrations/20260718160000_ai_os_foundation.sql

Pourquoi : Le fichier declare en en-tete qu'il n'est pas encore applique mais il est dans le dossier que Supabase CLI scanne automatiquement.

Impact : Si pgvector n'est pas active sur le projet Supabase, la migration echoue et bloque tout le reste.

Correction : Renommer avec prefixe _pending ou deplacer hors du dossier de migrations.

9. Securite

P1 Aucun header CSP/XFO/HSTS sur les reponses

Tous les endpoints (routes, backend, error-page)

Pourquoi : Aucune reponse HTML ou API ne definit Content-Security-Policy, X-Frame-Options, X-Content-Type-Options, Strict-Transport-Security.

Impact : XSS partiellement mitige par React mais pas de defense en profondeur. Clickjacking possible (pas de X-Frame-Options).

Correction : Ajouter dans vercel.json ou dans le json() helper et la reponse SSR.

P1 Reset password sans rate limiting

src/routes/reset-password.tsx:33-46

Pourquoi : Appelle supabase.auth.updateUser() avec un token de recovery. Aucune limitation cote client ni cote serveur.

Impact : Force brute possible si le token de recovery fuit. Consommation illimitée du quota Supabase Auth.

Correction : Rate limiting client-side + verifier que Supabase a une protection cote serveur.

P1 Trustpilot verification ID hardcoded dans les meta

src/routes/__root.tsx:57-59

Pourquoi : Un UUID de verification Trustpilot est hardcoded dans le <head>.

Impact : Si le token est re-emis, l'ancien reste dans le code source. Le squatting de domaine est legerement facilite.

Correction : Variable d'environnement: import.meta.env.VITE_TRUSTPILOT_VERIFICATION_ID.

P1 upsertTrade ne filtre pas par user_id

src/app/store/trades.ts:98-101

Pourquoi : L'upsert utilise la cle primaire (id). Si l'utilisateur A connait l'ID du trade de B, il peut l'ecrire.

Impact : Faille de securite inter-utilisateurs. RLS devrait proteger mais depend du SQL Supabase.

Correction : Ajouter .eq('user_id', userId) avant l'upsert et verifier RLS.

P1 VAPID public key hardcoded dans le source server

src/backend/push-crypto.server.ts:209-210

Pourquoi : Cle VAPID publique hardcoded en fallback si VAPID_PUBLIC_KEY env var est absente.

Impact : Rotation de cle impossible sans deploiement. Fallback silencieux sans warning.

Correction : Logger un warning a chaque utilisation du fallback. Documenter la rotation.

P1 globalThis.addEventListener('error') peut leak des secrets dans les logs

src/shared/error-capture.ts:11-16

Pourquoi : Les erreurs non capturees (contenant potentiellement des chemins de fichier, valeurs d'env, PII) sont capturees dans lastCapturedError.

Impact : Si une erreur contient un secret (API key, token), il est logge en clair. Les logs server sont souvent indexes et consultables.

Correction : Sanitizer les valeurs capturees avant de les logger. Ou scoper la capture au client-side.

10. Tests et Qualite

P0 Zero test dans toute la couche UI (src/app/)

src/app/ entier

Pourquoi : Aucun fichier .test.ts, .spec.ts ou __tests__ dans app/. Aucun test pour les composants, hooks, contextes, pages.

Impact : Aucune confiance dans les refactors UI. Impossible de valider les changements UI par CI.

Correction : Tests unitaires pour tradeCalcs, quantStats (pures) puis store layer (mocked Supabase).

P1 Pas de tests pour les engines metier

src/modules/trading/analysis/, src/modules/discipline/, src/modules/automation/, src/modules/notifications/

Pourquoi : Les 4 engines principaux (analyse de trade, discipline, automation pipeline, notifications) n'ont aucun test.

Impact : La logique metier la plus critique est non testee. Les calculs de scoring peuvent etre faux sans que personne le sache.

Correction : Tests unitaires pour chaque engine, en commençant par trading/analysis/engine.ts (pure, deterministe).

P1 Pas de tests d'integration (RLS, pipeline complet)

Toute la suite de test

Pourquoi : Tous les 81 tests sont des tests unitaires. Aucun test ne valide les RLS policies, le pipeline save-trade -> analyse -> notification.

Impact : Les RLS policies peuvent etre modifiees sans etre validees. Le pipeline complet peut casser sans alerte.

Correction : Tests d'integration avec un client Supabase anonymise. Au minimum pour le delete-account Edge Function.

P1 Module-level mutable state empeche les tests en parallele

src/app/store/accounts.ts:18-24, src/app/hooks/useScreenshotUrls.ts:5

Pourquoi : _activeAccountId et urlCache sont des variables d'etat au niveau module qui persistent entre les tests.

Impact : Tests executes en parallele -> cross-test contamination. Resultats non deterministes.

Correction : Remplacer par des mecanismes React (Context, refs) ou vider les caches en beforeEach.

P2 tsconfig.json n'inclut pas le dossier tests/

tsconfig.json:2

Pourquoi : L'include est ['src/**/*.ts', 'src/**/*.tsx', 'vite.config.ts', 'eslint.config.js'] - pas de 'tests/'.

Impact : Les fichiers de test ne sont pas type-checkes par tsc --noEmit. Les erreurs de type dans les tests passent inaperçues.

Correction : Ajouter 'tests/**/*.ts' a l'include.

11. Bundle, Build et Deploiement

P1 Build opaque derriere @lovable.dev/vite-tanstack-config

vite.config.ts + package.json:38

Pourquoi : defineConfig importe depuis un package npm (v2.6.4) qui encapsule toute la configuration TanStack Start, React, Tailwind, Nitro

Impact : L'equipe ne peut pas voir ni modifier les plugins Vite. Si le package devient incompatible ou non-maintenu, le build est bloqué. Sin

Correction : Vendoriser la configuration. Ou creer un fallback plain Vite config. Au minimum documenter ce que fait le package.

P2 Aucune optimisation de build (code splitting manuel)

vite.config.ts (via le package opaque)

Pourquoi : Pas de rollupOptions.output.manualChunks, pas de build.chunkSizeWarningLimit, pas de plugin d'optimisation d'images.

Impact : Bundle JS vintage probablement sous-optimal. recharts, react-markdown, lucide-react pourraient etre splites separement.

Correction : Auditer la taille du build et configurer manual chunks si necessaire.

P2 supabase/config.toml vide (1 ligne)

supabase/config.toml

Pourquoi : Seulement project_id. Pas d'auth config, pas de storage buckets, pas de CORS, pas de rate limiting.

Impact : Developpement local Supabase necessite configuration manuelle. Pas de parite avec la production.

Correction : Populer avec auth settings, storage bucket declarations, API rate limits.

P2 SUPABASE_SERVICE_ROLE_KEY manquant dans .env.example

.env.example

Pourquoi : La cle est requise par delete-account Edge Function mais absente du fichier d'exemple.

Impact : Un nouveau developpeur ne saura pas qu'il doit configurer cette variable. L'Edge Function echoue silencieusement.

Correction : Ajouter SUPABASE_SERVICE_ROLE_KEY= au .env.example.

12. SEO et Meta-donnees

P2 'Trade Tracker Pro' au lieu de 'TradeVault' dans les meta descriptions

src/routes/__root.tsx:67-84

Pourquoi : Les meta description et og:title contiennent 'Trade Tracker Pro' qui est un ancien nom du produit.

Impact : Les moteurs de recherche indexent le mauvais nom de marque. Les utilisateurs cherchant 'TradeVault' trouvent un resultat au nom

Correction : Corriger en 'TradeVault' partout.

P2 OG image est une icone d'app 512x512 au lieu d'une image de partage 1200x630

src/routes/__root.tsx:77,85

Pourquoi : og:image et twitter:image pointent vers /icon-512.png.

Impact : Les liens partages sur WhatsApp, Twitter, LinkedIn s'affichent avec un petit carre au lieu d'une carte riche.

Correction : Creer une vraie OG image 1200x630 et la référencer.

P2 Absence de meta description par page

Toutes les pages de l'application

Pourquoi : Les titres de page (document.title) et meta descriptions ne sont pas mis a jour dynamiquement selon la page.

Impact : Chaque page partage le meme titre et description. SEO degrade, pas de contenu unique par page.

Correction : Ajouter un hook usePageMeta(title, description) qui update document.title et les meta tags.

Score Global d'Architecture

Separation des couches : 25/100 (25%)

Event Bus architecture : 40/100 (40%)

Plateforme IA : 35/100 (35%)

SSR & Server Functions : 30/100 (30%)

React & UI : 45/100 (45%)

Design System : 55/100 (55%)

Mobile & Accessibilite : 40/100 (40%)

Supabase & Database : 30/100 (30%)

Securite : 35/100 (35%)

Tests & Qualite : 20/100 (20%)

Bundle & Build : 50/100 (50%)

SEO : 45/100 (45%)

SCORE GLOBAL : 450/1200 soit 38%

Interpretation

SCORE CRITIQUE. L'architecture de TradeVault montre des fondations solides sur le papier (event bus, moteurs purs, provider-agnostic) mais l'ecart entre le design aspire et la realite du code est dangereux pour une leve de fonds. Les P0 identifies (crash SSR, violation dependances, auth-middleware non standard, DB sans FK, migration dupquee) sont des bloqueurs de production. Les ~40% d'infrastructure IA type-only constituent un risque de perception majeur.

Top 10 Priorites

- 1. Supprimer les module-level side effects (notifications, automation) -> init() explicite
- 2. Fixer auth-middleware.ts: remplacer getClaims() par getUser()
- 3. Ajouter FK trades.user_id + bucket storage en migration + supprimer migration dupquee
- 4. Corriger la violation de dependance : extraire types metier dans modules/shared
- 5. Ajouter validation Zod sur toutes les server functions + rate limiting sur endpoints HTTP
- 6. Decider du sort de l'infrastructure AI inutilisee (backend/ai.functions vs modules/ai/)
- 7. Enregistrer les agents et outils declares dans le catalogue AI
- 8. Rendre emit() async avec await ou queue + flush
- 9. Ajouter tests pour engines metier + store layer + RLS integration
- 10. Ajouter headers de securite (CSP, XFO, HSTS) sur toutes les reponses